RÉPUBLIQUE DU CAMEROUN
* * * * * * * * *
Paix – Travail – Patrie
* * * * * * * * *
UNIVERSITÉ DE YAOUNDÉ I
* * * * * * * * *
ÉCOLE NATIONALE SUPÉRIEURE POLYTECHNIQUE DE YAOUNDÉ
* * * * * * * * *
DÉPARTEMENT DE GÉNIE INFORMATIQUE

REPUBLIC OF CAMEROON
* * * * * * * * *
Peace – Work – Fatherland
* * * * * * * * *
UNIVERSITY OF YAOUNDÉ I
* * * * * * * * *
NATIONAL ADVANCED SCHOOL OF ENGINEERING OF YAOUNDÉ
* * * * * * * * *
DEPARTMENT OF COMPUTER ENGINEERING

CHARTE DE GOUVERNANCE

Option :
Cybersécurité et Investigation Numérique

Travaux Pratiques : Première Mission

Rédigé par :
KALDADAK ADAMA
Matricule : 24P824

Examinateur :
Expert ***Thierry MINKA***
Enseignant ENSPY

Année académique 2025 / 2026

TABLE DES MATIÈRES

Liste des abréviations **1**

1 Contexte de la Mission **2**
1.1 Présentation de l'entreprise LiZbiZ 2
1.2 Problématiques identifiées 2
1.3 Système d'Information de LiZbiZ 3
1.4 Contexte réglementaire et contractuel 3
1.5 Analyse critique de la structure actuelle 4

2 Charte de Gouvernance Sécurité **5**
2.1 Objet et portée 5
2.2 Principes directeurs 5
2.3 Rôle et missions du RSSI 5
2.4 Instances de gouvernance 6
2.5 Obligations des acteurs 6

3 Matrice RACI, Gestion des Incidents Critiques **8**
3.1 Définition des rôles 8
3.2 Acteurs impliqués 8
3.3 Matrice RACI complète 9
3.4 Points clés et justifications 10

Conclusion **11**

LISTE DES TABLEAUX

1.1 Fiche d'identité – LiZbiZ 2
1.2 Inventaire des actifs principaux – LiZbiZ 3

2.1 Principes de gouvernance 5
2.2 Missions du RSSI 6
2.3 Instances de gouvernance sécurité 6
2.4 Obligations par acteur 7

3.1 Légende de la matrice RACI 8
3.2 Matrice RACI – Gestion des incidents critiques 9

LISTE DES ABRÉVIATIONS

Abréviation	**Définition**
ANSSI	Agence Nationale de la Sécurité des Systèmes d'Information
BIA	*Business Impact Analysis* (Analyse d'Impact Métier)
CNIL	Commission Nationale de l'Informatique et des Libertés
COMEX	Comité Exécutif
DPO	*Data Protection Officer* (Délégué à la Protection des Données)
DSI	Directeur des Systèmes d'Information
EBIOS RM	Expression des Besoins et Identification des Objectifs de Sécurité – Risk Manager
ERP	*Enterprise Resource Planning* (Progiciel de Gestion Intégré)
IoT	*Internet of Things* (Internet des Objets)
ISO	*International Organization for Standardization* (Organisation Internationale de Normalisation)
OIV	Opérateur d'Importance Vitale
PAS	Plan d'Action Sécurité
PCA	Plan de Continuité d'Activité
PCI-DSS	*Payment Card Industry Data Security Standard*
PDCA	*Plan-Do-Check-Act* (Planifier-Réaliser-Vérifier-Améliorer)
PDG	Président Directeur Général
PRA	Plan de Reprise d'Activité
PSSI	Politique de Sécurité des Systèmes d'Information
RACI	*Responsible-Accountable-Consulted-Informed*
RETEX	Retour d'EXpérience
RSSI	Responsable de la Sécurité des Systèmes d'Information
SI	Système d'Information
VLAN	*Virtual Local Area Network* (Réseau Local Virtuel)

CHAPITRE 1

CONTEXTE DE LA MISSION

➥ **Information**

Mission : En tant que consultants mandatés par la DSI de LiZbiZ, vous devez proposer au prochain Comité de Direction une charte de gouvernance simple définissant clairement le rôle du futur RSSI, et mettre en place un RACI pour la gestion des incidents critiques.

1.1 Présentation de l'entreprise LiZbiZ

LiZbiZ est une entreprise de e-commerce spécialisée dans la vente de matériel informatique et high-tech, avec une promesse de livraison en 24h grâce à une logistique automatisée (*Smart Logistics*). Elle compte 150 salariés, réalise un chiffre d'affaires de 45 millions d'euros et est cotée en bourse depuis 6 mois.

Table 1.1 – Fiche d'identité – LiZbiZ

Critère	Description
Secteur	E-commerce & Logistique
Siège social	Lyon, France
Effectif	150 salariés
Chiffre d'affaires	45 millions EUR
Statut	Société Anonyme (SA), cotée en bourse
PDG	Jean-Pierre L.
DSI (commanditaire)	Sophie M.
Poste RSSI	**VACANT**

1.2 Problématiques identifiées

✘ **Risque identifié**

Suite à une croissance rapide (de 20 à 150 employés en 2 ans), la gouvernance sécurité n'a pas

suivi. Trois lacunes critiques ont été identifiées :

- Poste de RSSI vacant : la DSI cumule deux postes incompatibles (DSI et RSSI).
- Aucun Comité de Sécurité : la Direction n'est pas informée des risques techniques.
- Processus de sécurité gérés à l'oral : aucun RACI formel.

1.3 Système d'Information de LiZbiZ

Le SI de LiZbiZ est le cœur de l'entreprise. Il gère à la fois la vente en ligne et l'automatisation de l'entrepôt.

Table 1.2 – Inventaire des actifs principaux – LiZbiZ

Catégorie	Actif	Description
Infrastructure	Serveur principal	Dell PowerEdge R740 (ESXi)
Infrastructure	Baie de stockage	NAS Synology (données et sauvegardes)
Réseau	Commutateurs	Cisco Catalyst (cœur), Netgear (accès)
Logiciels	ERP	Odoo v15 (stocks, ventes, comptabilité)
Logiciels	E-commerce	Site web sous Magento 2
Logiciels	Base de données	PostgreSQL 13 (données clients)
Logiciels	Annuaire	Windows Server 2019 (Active Directory)
Périphériques	Terminaux	40 postes Windows 10, 10 laptops
Périphériques	IoT Logistique	50 scanners RFID, 20 tablettes

La topologie réseau est segmentée en VLANs :

- **VLAN 10 (DMZ) :** Accessible depuis Internet. Héberge le site marchand. Haut risque.
- **VLAN 20 (Applicatif) :** Cœur du système. Contient l'ERP et la base de données. Aucun accès direct externe autorisé.
- **VLAN 30 (Bureau) :** Postes de travail du siège. Accès Internet et applicatif.
- **VLAN 40 (IoT/Logistique) :** Réseau isolé pour les scanners et capteurs. Faible sécurité par conception.
- **VLAN 99 (Administration) :** Accès de gestion aux équipements. Très sensible.

1.4 Contexte réglementaire et contractuel

LiZbiZ est soumise à des contraintes légales strictes qui constituent le point de départ de l'analyse de risque :

1. **Loi n°2024/017 du 23 décembre 2024 :** Protection des données à caractère personnel des clients et employés (Autorité de protection des données personnelles – délai de mise en conformité : juin 2026).
2. **PCI-DSS :** Acceptation des paiements par carte bancaire (niveau 1).
3. **Loi de Programmation Militaire (LPM) :** Opérateur d'importance vitale (OIV) potentiel car lié à la logistique critique.

1.5 Analyse critique de la structure actuelle

La croissance rapide de LiZbiZ a créé plusieurs problèmes structurels de gouvernance :

1. **Cumul de postes incompatibles :** La DSI occupe simultanément les fonctions de DSI et de RSSI. Elle valide les accès qu'elle crée elle-même. Le contrôle interne est inexistant.
2. **Manque de visibilité :** Pas de Comité de Sécurité. La Direction Générale n'est pas informée des risques techniques.
3. **Absence de RACI formel :** Les processus de sécurité sont gérés à l'oral, ce qui engendre des oublis et des erreurs.

CHAPITRE 2

CHARTE DE GOUVERNANCE SÉCURITÉ

2.1 Objet et portée

La présente charte définit les principes, responsabilités et processus régissant la gouvernance de la sécurité des systèmes d'information de LiZbiZ. Elle s'applique à l'ensemble des salariés, prestataires et partenaires ayant accès au Système d'Information. En l'absence de RSSI, cette charte constitue le premier acte formel de gouvernance de l'entreprise et servira de référence pour toutes les décisions de sécurité à venir.
Référentiels applicables : ISO 27001, ISO 31000, Loi n°2024/017 du 23 décembre 2024 relative à la protection des données à caractère personnel (Cameroun), PCI-DSS, cycle PDCA.

2.2 Principes directeurs

La gouvernance de la sécurité de LiZbiZ repose sur cinq principes fondamentaux qui doivent guider chaque décision, chaque investissement et chaque arbitrage en matière de sécurité du SI.

Table 2.1 – Principes de gouvernance

Principe	Description
Alignement stratégique	La sécurité soutient les objectifs métier. Elle ne doit pas être un frein.
Moindre privilège	Chaque utilisateur dispose uniquement des droits nécessaires à sa fonction.
Responsabilité partagée	Chaque acteur est responsable à son niveau. La Direction est redevable (*Accountable*) devant les actionnaires.
Amélioration continue	Le cycle PDCA guide toutes les décisions de sécurité.
Transparence	L'état de la sécurité est présenté régulièrement au COMEX.

2.3 Rôle et missions du RSSI

Le RSSI est le point focal sécurité de LiZbiZ. Il rapporte directement au PDG pour garantir son indépendance vis-à-vis de la DSI.

Table 2.2 – Missions du RSSI

Domaine	Mission
Politique de sécurité	Définir et maintenir la PSSI. Proposer et défendre le budget sécurité au COMEX.
Analyse de risque	Piloter l'analyse annuelle (EBIOS RM / ISO 27005). Tenir à jour le registre des risques et le Plan d'Action Sécurité (PAS).
Gestion des incidents	Être le décideur (A) sur les incidents critiques. Coordonner la réponse (ISO 27035). Notifier la CNIL et l'ANSSI si nécessaire.
Conformité	Vérifier la conformité à la Loi 2024/017, PCI-DSS. Superviser les audits (ISO 19011).
Sensibilisation	Mettre en place le programme de sensibilisation annuel. Organiser les exercices de crise.
Reporting	Tableau de bord mensuel (Comité de Sécurité) et trimestriel (COMEX).

2.4 Instances de gouvernance

Pour assurer un pilotage efficace de la sécurité, trois instances sont mises en place avec des niveaux de responsabilité distincts. Elles forment la colonne vertébrale de la gouvernance sécurité de LiZbiZ.

Table 2.3 – Instances de gouvernance sécurité

Instance	Fréquence	Rôle
COMEX	Trimestrielle	Décisions stratégiques, budgets sécurité, arbitrages de risques majeurs.
Comité de Sécurité	Mensuelle	Suivi des indicateurs, incidents en cours, avancement du PAS. Participants : RSSI, DSI, DPO, représentants métiers.
Cellule de Crise	Si incident P1/P2	Décision sous pression, communication externe. Déclenchée par le RSSI.

2.5 Obligations des acteurs

La sécurité est une responsabilité partagée. Chaque acteur de LiZbiZ a des obligations précises en matière de sécurité du SI. Le non-respect de ces obligations peut engager la responsabilité civile et pénale de l'acteur concerné.

Table 2.4 – Obligations par acteur

Acteur	**Obligations principales**
PDG	Approuver la PSSI. Porter la sécurité au niveau COMEX. Être redevable devant les actionnaires et les régulateurs.
RSSI	Piloter la stratégie sécurité. Être *Accountable* sur la gestion des risques et des incidents critiques.
DSI	Mettre en œuvre les mesures techniques décidées par le RSSI. Ne pas cumuler les fonctions DSI et RSSI.
DPO	Veiller au respect de la Loi 2024/017. Être consulté pour tout traitement de données personnelles. Gérer les déclarations auprès de l'Autorité de protection des données personnelles.
Tous les salariés	Respecter la charte informatique. Signaler tout incident au RSSI dans les 2 heures. Suivre les formations de sensibilisation.

CHAPITRE 3

MATRICE RACI, GESTION DES INCIDENTS CRITIQUES

La matrice RACI est l'outil central permettant de clarifier qui fait quoi lors d'un incident de sécurité. Elle répond directement à la lacune identifiée chez LiZbiZ : l'absence de processus formel avec des responsabilités clairement attribuées. Chaque activité du cycle de gestion d'incident (ISO 27035) est associée à un décideur unique (A) et à des exécutants identifiés (R).

3.1 Définition des rôles

La matrice RACI repose sur quatre rôles distincts. Il est essentiel de comprendre la différence entre **Responsible** (celui qui fait) et **Accountable** (celui qui répond du résultat). Un seul acteur peut être *Accountable* par tâche : c'est le principe de l'unique tête de file.

Table 3.1 – Légende de la matrice RACI

Code	Rôle	Signification
R	Responsible	Réalise la tâche. Peut être partagé entre plusieurs acteurs.
A	Accountable	Décideur unique par tâche. Répond du résultat final devant la Direction.
C	Consulted	Expert consulté avant la décision. Communication bilatérale.
I	Informed	Informé du résultat uniquement. Communication unilatérale.

3.2 Acteurs impliqués

Six acteurs sont impliqués dans la gestion des incidents critiques chez LiZbiZ. Leurs rôles dans la matrice sont définis en fonction de leurs attributions fonctionnelles et de leur niveau de responsabilité dans l'organisation.

- **RSSI** – Responsable de la Sécurité des SI (futur poste)
- **DSI** – Sophie M., Direction des Systèmes d'Information
- **Éq. Tech.** – Équipe technique (administrateurs systèmes/réseau)
- **PDG** – Jean-Pierre L., Direction Générale
- **DPO** – Délégué à la Protection des Données
- **Com./Jur.** – Communication et service juridique

3.3 Matrice RACI complète

La matrice ci-dessous couvre l'intégralité du cycle de gestion d'un incident critique selon la norme ISO 27035, de la détection initiale jusqu'au retour d'expérience (RETEX). Les phases sont colorées en bleu pour faciliter la lecture. Pour chaque activité, un seul acteur porte le rôle **A** (*Accountable*).

Table 3.2 – Matrice RACI – Gestion des incidents critiques

Activité	RSSI	DSI	Éq. Tech.	PDG	DPO	Com./Jur.
Phase 1 – Détection et Qualification						
Détection de l'anomalie	**R**	C	**R**	I	–	–
Qualification (P1/P2/P3)	**A**	C	**R**	I	C	–
Déclenchement cellule de crise	**A**	I	I	I	I	I
Phase 2 – Confinement						
Stratégie de confinement	**A**	C	**R**	–	–	–
Isolation des systèmes compromis	**A**	C	**R**	–	–	–
Activation PCA / basculement	**A**	**R**	**R**	I	–	–
Phase 3 – Investigation et Éradication						
Investigation forensique	**A**	C	**R**	–	C	C
Analyse des causes racines	**A**	C	**R**	I	–	–
Éradication et patching	**A**	C	**R**	–	–	–
Phase 4 – Communication						
Communication interne	**A**	**R**	–	I	I	**R**
Communication externe (presse)	C	–	–	**A**	C	**R**
Déclaration à l'Autorité	C	–	–	I	**A**	**R**
Phase 5 – Retour à la Normale et RETEX						
Validation retour à la normale	**A**	**R**	**R**	I	–	–
Rapport RETEX	**A**	C	**R**	I	C	–
Présentation RETEX au COMEX	**R**	I	–	**A**	I	–

3.4 Points clés et justifications

L'analyse de la matrice fait ressortir plusieurs constats importants qui justifient les choix de gouvernance proposés dans la charte :

- Le **RSSI** est *Accountable* sur toutes les phases techniques. C'est la justification centrale de la création du poste.
- Le **PDG** est *Accountable* uniquement sur la communication externe et la validation du RETEX au COMEX.
- La **DSI** ne porte plus le rôle A sur les incidents, mettant fin au cumul de postes incompatibles (DSI + RSSI).
- Le **DPO** est *Accountable* sur toute déclaration auprès de l'Autorité de protection des données personnelles (obligation Loi 2024/017 : délai 72 heures).
- La règle d'unicité du A est respectée : une seule case A par ligne.

✔ Recommandation

Actions prioritaires à mettre en œuvre avant la prochaine mission :

1. **(P1 – Immédiat)** Recruter ou nommer le RSSI et lui remettre cette charte.
2. **(P1 – 1 mois)** Auditer et révoquer les droits ERP des anciens collaborateurs (principe du moindre privilège).
3. **(P2 – 1 mois)** Créer le Comité de Sécurité mensuel.
4. **(P2 – 2 mois)** Planifier les mises à jour du serveur Web (VLAN 10 / DMZ).
5. **(P3 – 3 mois)** Lancer l'élaboration du Plan de Continuité d'Activité (PCA).

CONCLUSION

La charte de gouvernance et la matrice RACI proposées dans ce travail pratique répondent directement aux trois lacunes critiques identifiées chez LiZbiZ : poste de RSSI vacant, absence d'instances de gouvernance, et processus gérés à l'oral sans responsabilités formalisées.

La charte crée un RSSI indépendant rattaché au PDG, instaure trois instances de gouvernance (COMEX, Comité de Sécurité, Cellule de Crise) et définit clairement les obligations de chaque acteur. Elle s'appuie sur les référentiels ISO 27001, ISO 31000, Loi n°2024/017 du 23 décembre 2024 (protection des données à caractère personnel, Cameroun) et PCI-DSS.

La matrice RACI pour la gestion des incidents garantit que chaque phase du cycle ISO 27035 (Détection, Confinement, Investigation, Communication, RETEX) dispose d'un décideur unique (*Accountable*) et d'exécutants clairement identifiés. Elle élimine le cumul de postes incompatibles en séparant clairement les rôles de la DSI et du futur RSSI, et assure la conformité à la Loi 2024/017 via le DPO.

Ces deux livrables constituent le socle minimal de gouvernance que LiZbiZ doit mettre en place en priorité, avant même de lancer son analyse de risque formelle selon la méthode EBIOS RM. Sans gouvernance claire, les résultats d'une analyse de risque ne peuvent pas être portés ni suivis efficacement.